Cross-account object access

Summary

Severity: High
Vulnerability class: IDOR
Affected target: https://example.test/api/invoices/123

An authenticated user can read another account’s invoice.

Steps to Reproduce

1. Log in as account A.
2. Request account B’s invoice identifier.

Proof of Concept

The response contains account B’s invoice data.

Request

```
GET /api/invoices/123 HTTP/1.1
```

Response

```
{"owner":"account-b"}
```

Impact

Confidential invoice data is disclosed across tenant boundaries.

Remediation

Authorize the invoice owner before returning the object.

Scoring and Timeline

CVSS vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
CVSS score: 8.1
Affected users: Any authenticated customer.
Discovered at: 2026-08-07T12:00:00.000Z